

Plan Sécurité & Conformité (Stripe Project)

Contexte et objectifs

Dans un contexte de plateforme financière mondiale comme Stripe, la sécurité et la conformité sont des priorités absolues. L'infrastructure traite des millions de transactions quotidiennes contenant des informations hautement sensibles : données bancaires, identités clients, historiques de paiements. Ce plan présente les mesures mises en place pour garantir la confidentialité, l'intégrité et la disponibilité des données, en conformité avec les normes RGPD, PCI-DSS et CCPA.

Données sensibles concernées

Type de données	Exemples	Niveau de criticité
Données personnelles clients	Nom, email, adresse, IP	Élevé
Données financières	IBAN, carte, montant, devise	Critique
Données marchands	Identité, pays, volume de ventes	Élevé
Logs applicatifs	Identifiants de session, erreurs, évènements API	Moyen
Données modèles ML	Scores, features, signaux comportementaux	Moyen

Principes généraux de sécurité

Les politiques de sécurité appliquées reposent sur les standards internationaux ISO 27001 et PCI-DSS :

- Chiffrement des données
- Contrôle d'accès par rôles (RBAC)
- Journalisation et traçabilité
- Masquage / pseudonymisation
- Cloisonnement réseau
- Sauvegarde et reprise

Mesures par couche (OLTP / OLAP / NoSQL)

OLTP (PostgreSQL / NeonDB)

- Stockage transactionnel chiffré au repos (AES-256).
- Masquage sur les champs sensibles (email, carte).
- Audit automatique des opérations d'écriture.

OLAP (Data Warehouse PostgreSQL-DW)

- Données pseudonymisées avant ingestion.
- Accès en lecture seule pour les analystes.
- Sauvegarde quotidienne sur stockage chiffré (S3 ou équivalent).

NoSQL (MongoDB)

- Stockage JSON
- Chiffrement sur toutes les connexions.
- Rotation des clés et logs d'accès sur `clickstream\_events` et `fraud\_features`.

Conformité réglementaire

Norme	Exigence principale	Mesure mise en œuvre
RGPD (UE)	Protection des données personnelles	Pseudonymisation, consentement, droit à l'oubli
PCI-DSS	Protection des données de paiement	Chiffrement AES, segmentation réseau, logs d'audit
CCPA (USA)	Droits d'accès et suppression client	API interne de gestion des droits et effacement

Bonnes pratiques et gouvernance

- Rotation des clés de chiffrement tous les 90 jours.
- MFA obligatoire pour les comptes administrateurs.
- Politique de mots de passe forts (12+ caractères, rotation semestrielle).
- DPO (Data Protection Officer) responsable du suivi RGPD.
- Revue trimestrielle des accès utilisateurs.
- Plan d'audit interne annuel (ISO 27001).